



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Review intake draft: CVE-2026-7473 Arista Extensible Operating System Incomplete Comparison with Missing Factors Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Review intake draft: CVE-2026-7473 Arista Extensible Operating System Incomplete Comparison with Missing Factors Vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-7473 is an actively exploited Arista EOS tunnel-decapsulation validation flaw that can cause an affected switch to decapsulate and forward tunneled traffic for a configured decapsulation IP even when the incoming tunnel protocol is not one the device was intended to accept. Authoritative public records describe the root issue as a failure to verify the tunnel protocol type when features such as VXLAN, `ip decap-group`, or GRE tunnel decapsulation are configured.

The business risk is less about traditional host compromise and more about control-plane trust failure inside critical network paths. In practical terms, an attacker who can reach a decapsulation IP on an exposed or poorly segmented EOS device may be able to bypass intended tunnel-protocol restrictions, inject unexpected tunneled traffic into the switching fabric, and undermine segmentation assumptions that network and security teams rely on for east-west isolation, tenant separation, and service-boundary enforcement.

Although the published CVSS values are only medium (`6.9` under CVSS v4.0 and `5.8` under CVSS v3.1), CISA added the issue to the Known Exploited Vulnerabilities Catalog on `2026-06-09`, which materially raises response priority. The vendor-advisory snippets reviewed for this task also indicate an important operational constraint: Arista does not appear to be positioning this as a simple patch-only problem. Instead, mitigation centers on configuration hardening and TCAM/UDF-based protocol filtering at tunnel endpoints, which means defenders should plan for inventory, configuration review, and control-validation work rather than assuming a standard software-upgrade motion fully resolves exposure.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what is `CVE-2026-7473`, which Arista EOS deployments are realistically exposed, what is confirmed about exploitation and mitigation, and what concrete actions should defenders take now to reduce tunnel-decapsulation bypass risk?

2.1 Vulnerability Metadata

Field	Value
CVE	`CVE-2026-7473`
Vulnerability name	`Arista Extensible Operating System Incomplete Comparison with Missing Factors Vulnerability`
Product / component	`Arista EOS tunnel decapsulation features (for example VXLAN, ip decap-group, and GRE tunnel decapsulation paths)`
Weakness	`CWE-1023` Incomplete Comparison with Missing Factors
Severity	`6.9 / MEDIUM` (CVSS v4.0), `5.8 / MEDIUM` (CVSS v3.1)
CVSS v4.0 vector	`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:L/SA:N`
CVSS v3.1 vector	`AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:N`
Attack vector	Network
Privileges required	None
User interaction	None
Confirmed exploitation status	Reported as exploited in the wild; added to CISA KEV on `2026-06-09`
Publication date	`2026-06-05` (NVD publication)

CISA due date	`2026-06-23`
Vendor advisory family	`Arista Security Advisory 0137`

2.2 Key Intelligence Judgments

- 1. This is a network-boundary and segmentation-bypass issue, not a classic endpoint or server code-execution vulnerability.
- 2. Only EOS devices configured as tunnel decapsulation endpoints appear to be in scope; unconfigured EOS devices should not be treated as equally exposed.
- 3. The highest-risk environments are those where VXLAN, GRE, or `ip decap-group` decapsulation IPs are reachable from less-trusted network zones, partners, tenants, or internet-adjacent paths.
- 4. The lack of a simple vendor patch path in reviewed advisory snippets means defenders should prioritize configuration controls, tunnel-endpoint reachability reduction, and telemetry-based validation rather than waiting for a routine upgrade window.
- 5. Public reporting confirms exploitation but does not yet provide named threat actors, public proof-of-concept tooling, or a stable exploit-specific IOC set; detection must therefore focus on exposure inventory, unexpected traffic patterns, and suspicious configuration activity.

3. Source Review and Confidence

Source	Contribution	Confidence
Arista Security Advisory 0137 search-result snippets	Primary vendor context for affected EOS trains, required vulnerable configuration, mitigation direction, and the statement that no software upgrade path is planned due to configuration-break risk	High
NVD JSON 2.0 CVE record	Canonical public description, publication timestamps, CVSS vectors, `CWE-1023`, KEV enrichment, and normalized references	High
CISA KEV JSON feed	Primary source for KEV inclusion date, due date, required action, and concise exploitation statement	High
CISA vulnerability bulletin (`sb26-159`)	Secondary corroboration that the issue was publicly summarized in weekly federal vulnerability reporting	Medium
OpenCVE / GitHub advisory mirrors	Secondary corroboration of the descriptive text and public distribution of the CVE record	Medium

Confidence is high that the vulnerability exists, that exploitation has been reported in the wild, and that the vulnerable condition depends on configured tunnel decapsulation behavior on Arista EOS. Confidence is also high that the issue is fundamentally an integrity / policy-enforcement problem caused by protocol-type validation failure rather than a confidentiality-heavy or availability-heavy failure.

Confidence is only medium on the exact affected-hardware matrix and the most detailed workaround implementation steps because the directly accessible public evidence for this review came from vendor-advisory snippets and NVD normalization

rather than a fully retrievable vendor advisory document body. The reviewed snippets consistently indicate affected EOS trains from `4.31.x` through `4.36.x`, the requirement for tunnel-endpoint decapsulation configuration, and a TCAM/UDF-based mitigation path. Those points are suitable for operational triage, but engineers should still validate platform-specific applicability against the live Arista advisory before making production TCAM changes.

4. Key Findings

4.1 Vulnerability Mechanics

NVD describes the issue as follows: when an affected Arista EOS platform is configured for tunnel decapsulation, the switch may incorrectly decapsulate and forward an unexpected tunneled packet if the packet targets the configured decapsulation IP. The core defect is that the switch does not verify the tunnel protocol type before processing the packet. In effect, the device can treat traffic as eligible for decapsulation based on destination and decap context without fully validating whether the outer tunnel protocol matches the administrator's intended design.

That behavior matters because network architects often assume tunnel endpoints only decapsulate explicitly configured protocols on explicitly intended paths. If that assumption fails, segmentation, service chaining, overlay isolation, or boundary filtering can be weakened even if the rest of the environment is functioning as designed.

4.2 Exploitation Preconditions

Required condition	Why it matters
Device is configured as a tunnel endpoint with a decapsulation IP	Vendor advisory snippets explicitly state this is the prerequisite for vulnerability
Example features include VXLAN VTEP, GRE tunnel endpoint, or `ip decap-group`	These are the configurations public sources name as representative exposure patterns
Attacker can send traffic to the decapsulation IP from an untrusted or less-trusted path	Without reachability to the decap IP, exploitability is materially reduced
Defensive protocol filtering is absent or incomplete	The available mitigation guidance centers on enforcing allowed tunnel protocols explicitly

The reviewed source set does not support claiming that every EOS deployment is automatically vulnerable. Exposure depends on reachable decapsulation configuration, which is why inventory and configuration review are the first operational priorities.

4.3 Affected Versions and Remediation Posture

Category	Assessment
Affected software trains	Vendor-advisory snippets reviewed for this task consistently indicate EOS `4.31.x`, `4.32.x`, `4.33.x`, `4.34.x`, `4.35.x`, and `4.36.x` are affected
Unaffected / later trains	Search-result snippets suggest trains newer than `4.36.x` are not part of the affected-software list
Fixed software path	Reviewed advisory snippets indicate `no software upgrade path is planned` because a code fix could break existing configurations
Practical remediation model	Configuration hardening, explicit packet-class / UDF / TCAM policy updates, and reachability reduction at tunnel endpoints

This remediation posture is operationally important. Many vulnerability workflows assume patching is the primary control and compensating controls are temporary. For `CVE-2026-7473`, the reviewed vendor evidence points in the opposite direction:

mitigation appears to be configuration-centric by design, and in some cases may consume scarce hardware qualifiers or require removing other TCAM features to make room for new enforcement logic.

4.4 Exposure Interpretation

Exposure pattern	Why it matters
Internet-adjacent or partner-reachable VXLAN / GRE decapsulation IPs	Creates the clearest remote attack path to trigger unexpected decapsulation behavior
Multi-tenant or segmented data-center fabrics relying on overlay trust	Raises the impact of segmentation bypass or unintended traffic injection
EOS devices using `ip decap-group` for selective decapsulation workflows	Matches one of the explicitly named vulnerable feature patterns
Platforms already resource-constrained on TCAM / UDF qualifiers	Can make mitigation rollout slower or create tradeoffs with other security or forwarding features
Well-segmented devices with no reachable untrusted path to the decap IP	Reduces exploit opportunity but does not eliminate the need to validate configuration and compensating controls

4.5 ATT&CK Mapping Caveat

A precise MITRE ATT&CK mapping is not strongly supported by the reviewed public record because the issue is best understood as a network-policy bypass in tunnel handling rather than a classic host exploit chain. The closest ATT&CK analogue is `T1190` (`Exploit Public-Facing Application`) when a decapsulation IP is externally reachable, but Lost Boys Cyber assigns that mapping only low confidence because ATT&CK does not cleanly model tunnel-protocol validation failures on network infrastructure.

5. Threat Context

The exploitation value of `CVE-2026-7473` comes from trust transitivity inside network fabrics. Arista EOS tunnel endpoints often sit in places where operators assume the outer encapsulation itself is a trustworthy signal about where traffic originated and how it should be handled. If an attacker can deliver unexpected tunnel types to a valid decapsulation IP and the device processes that traffic anyway, then security assumptions around segmentation, tenant isolation, service exposure, and path validation can all become less reliable.

In practical adversary terms, the issue is most attractive in environments where tunnel endpoints bridge security zones or where overlay networks carry sensitive east-west traffic. Likely high-value targets include data-center leaf/spine fabrics, environments with tenant overlays, service-provider-style encapsulation boundaries, and enterprises using GRE or VXLAN to connect sensitive enclaves. The impact is not necessarily immediate device takeover; it can instead be unauthorized forwarding, policy bypass, or delivery of traffic into places defenders did not expect it to reach.

The reviewed public record does not identify a named threat actor, exploit kit, or ransomware program using this flaw. CISA's KEV decision is therefore the strongest public signal that real-world exploitation has occurred. Defenders should treat that as sufficient reason to act even though public exploitation details remain sparse.

6. Detection and Hunting

Because the public record does not provide a high-fidelity exploit signature, detection should emphasize three layers:

- identify EOS devices that are actually configured as tunnel decapsulation endpoints
- verify which of those endpoints remain reachable from untrusted or low-trust networks
- watch for unexpected tunnel traffic, configuration changes, and mitigation drift around decapsulation IPs

6.1 Detection Logic Summary

Signal	Telemetry source	Analytic goal
EOS devices configured with VXLAN VTEP, GRE tunnel interfaces, or `ip decap-group`	Running config, CMDB, network automation inventory	Identify the actually exposed population
Traffic arriving at a decapsulation IP using an outer protocol that does not match the allowed design	NetFlow/IPFIX, firewall logs, packet brokers, network detection sensors	Detect likely exploit attempts or policy-bypass testing
Config changes touching `tcam profile`, UDF qualifiers, PACLs, MAC ACLs, tunnel interfaces, VXLAN, or decap groups	Arista syslog, config-management audit logs, AAA command accounting	Detect mitigation rollout, drift, or suspicious weakening of controls
Post-mitigation traffic that still reaches decap IPs with unexpected protocol/port combinations	Flow telemetry, packet captures, IDS, firewall logs	Validate that hardening controls are actually blocking the unwanted path
Sudden spikes of tunnel-related drops or policy hits after mitigation deployment	Syslog, hardware counters, SIEM	Distinguish attempted abuse from benign misconfiguration and tune rules

6.2 Example KQL Hunt - Unexpected Traffic to Decapsulation IPs

Replace the example IPs and allowed transport values with the organization's real tunnel endpoints before production use.

```
let TunnelEndpoints = datatable(DestinationIP:string, ExpectedOuterTransport:string)
[
    "203.0.113.10", "UDP/4789",
    "203.0.113.20", "GRE"
];
CommonSecurityLog
| where isnotempty(DestinationIP)
| where DestinationIP in (TunnelEndpoints | project DestinationIP)
| extend ObservedOuterTransport = case(
    Protocol == "47", "GRE",
    Protocol == "17" and DestinationPort == 4789, "UDP/4789",
    strcat("PROTO_", Protocol, "/", tostring(DestinationPort))
)
| join kind=leftouter TunnelEndpoints on DestinationIP
| where ObservedOuterTransport != ExpectedOuterTransport
| project TimeGenerated, DeviceName, SourceIP, DestinationIP, DestinationPort, Protocol,
ObservedOuterTransport, ExpectedOuterTransport, RequestClientApplication
| order by TimeGenerated desc
```

6.3 Example Splunk Hunt - Tunnel Endpoint Exposure and Drift

```
(index=netflow OR index=firewall OR index=arista_syslog)
(
    dest_ip="203.0.113.10" OR dest_ip="203.0.113.20"
    OR message="*vxlan*" OR message="*decap-group*" OR message="*tcam profile*" OR message="*udf*" OR
    message="*pacl*" OR message="*mac acl*"
)
| eval observed_transport=case(protocol=47,"GRE", protocol=17 AND dest_port=4789,"UDP/4789", true(),
protocol."/" . dest_port)
| stats count min(_time) as first_seen max(_time) as last_seen values(src_ip) as src_ip
values(observed_transport) as observed_transport values(message) as config_events by host dest_ip
| convert ctime(first_seen) ctime(last_seen)
| sort - last_seen
```

6.4 Example Syslog-Focused KQL Hunt - Configuration Changes

```
Syslog
| where TimeGenerated > ago(30d)
| where SyslogMessage has_any ("vxlan", "decap-group", "interface tunnel", "tcam profile", "udf",
"pac1", "mac acl")
| project TimeGenerated, Computer, ProcessName, SeverityLevel, SyslogMessage
| order by TimeGenerated desc
```

6.5 Hunt Questions

- 1. Which EOS devices currently expose a decapsulation IP for VXLAN, GRE, or `ip decap-group` workflows?
- 2. For each decapsulation IP, which source zones, addresses, or autonomous systems can actually reach it today?
- 3. Do flow logs show traffic to those IPs using outer protocols other than the one the design intends?
- 4. After mitigation changes, do counters, logs, or packet captures show blocked unexpected tunnel traffic that would otherwise have been accepted?
- 5. Did any recent configuration changes weaken PACLs, MAC ACLs, UDF qualifiers, or TCAM profiles on devices in the exposed set?

6.6 ATT&CK-Informed Framing

Technique	Name	Confidence	Rationale
`T1190`	Exploit Public-Facing Application	Low	Closest ATT&CK analogue when a decapsulation IP is reachable from untrusted networks, but ATT&CK does not map this network-device tunnel-validation flaw cleanly

7. Recommendations

Priority	Owner	Action
Critical	Network Engineering	Identify every EOS device configured as a VXLAN VTEP, GRE decapsulation endpoint, or `ip decap-group` endpoint and validate whether the decapsulation IP is reachable from any untrusted path.
Critical	Network Security	Apply vendor-directed mitigations to explicitly restrict allowed tunnel protocols at decapsulation IPs, including PACL / MAC ACL / UDF / TCAM changes where supported.
Critical	Architecture / Platform Owners	Reduce exposure by limiting reachability to decapsulation IPs from internet-adjacent, partner, tenant, and lower-trust networks wherever the business design permits.
High	SOC / Detection Engineering	Stand up hunts for unexpected protocol/port combinations hitting decapsulation IPs and for configuration changes touching tunnel, PACL, MAC ACL, UDF, and TCAM settings.
High	Change Management	Treat TCAM and qualifier consumption as

		a real implementation risk; validate mitigation changes in lab or maintenance windows because reviewed vendor snippets indicate hardware-constraint tradeoffs may apply.
High	Incident Response	Retrospectively review flow, firewall, and packet-capture data for suspicious traffic to decapsulation IPs from the disclosure window (`2026-06-05`) onward, prioritizing internet-adjacent and cross-tenant paths.
Medium	Threat Intelligence	Re-check the Arista advisory, NVD record, and KEV catalog over the following patch cycles for additional exploitation detail, updated workaround guidance, or changes to the affected-software statement.

Additional analyst guidance:

- Do not assume a medium CVSS score means low operational urgency; KEV inclusion and network-boundary impact make this a high-priority engineering issue.
- Do not assume a routine EOS upgrade alone will fix the problem; reviewed vendor evidence indicates mitigation may remain configuration-centric.
- Where the organization lacks reliable flow telemetry for tunnel endpoints, use this CVE as a forcing function to improve visibility before the next infrastructure-facing exploitation cycle.

8. References

- 1. Arista, `Security Advisory 0137` - <https://www.arista.com/en/support/advisories-notice/security-advisory/24005-security-advisory-0137>
- 2. NVD, `CVE-2026-7473 Detail` - <https://nvd.nist.gov/vuln/detail/CVE-2026-7473>
- 3. NVD JSON 2.0 API query - <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-7473>
- 4. CISA Known Exploited Vulnerabilities JSON feed - https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- 5. CISA Known Exploited Vulnerabilities Catalog entry - https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-7473
- 6. CISA, `Vulnerability Summary for the Week of June 1, 2026` - <https://www.cisa.gov/news-events/bulletins/sb26-159>
- 7. OpenCVE, `CVE-2026-7473 - Vulnerability Details` - <https://app.opencve.io/cve/CVE-2026-7473>
- 8. GitHub Advisory Database, `GHSA-mcx4-vm6v-r473` - <https://github.com/advisories/GHSA-mcx4-vm6v-r473>